Started on	Saturday, 4 April 2026, 1:24 PM
State	Finished
Completed on	Saturday, 4 April 2026, 1:34 PM
Time taken	9 mins 46 secs
Marks	20.00/20.00
Grade	**10.00** out of 10.00 (**100**%)

Question **1**

Correct

Mark 1.00 out of 1.00

SQL Injection pertama kali didokumentasikan secara resmi pada tahun:

- a. 1998 ✔
- b. 1995
- c. 1996
- d. 1997

Your answer is correct.

The correct answer is: 1998

Question **2**

Correct

Mark 1.00 out of 1.00

Konfigurasi cookie session yang paling aman secara umum dalam aplikasi web adalah:

- a. Secure=false, HttpOnly=true, SameSite=Lax. Untuk kemudahan pengujian di lingkungan development
- b. Secure=false, HttpOnly=false, SameSite=None. Untuk kompatibilitas maksimal
- c. Secure=true, HttpOnly=true, SameSite=Strict. Hanya HTTPS, tidak bisa diakses JS, tidak dikirim lintas domain ✔
- d. Secure=true, HttpOnly=false, SameSite=None. Agar JavaScript dapat membaca cookie untuk validasi

Your answer is correct.

The correct answer is: Secure=true, HttpOnly=true, SameSite=Strict. Hanya HTTPS, tidak bisa diakses JS, tidak dikirim lintas domain

Question **3**

Correct

Mark 1.00 out of 1.00

Command Injection terjadi ketika penyerang menyisipkan perintah sistem operasi ke dalam input aplikasi. Dampak paling kritis yang dapat terjadi adalah:

- a. Kebocoran data melalui XSS ke browser pengguna lain
- b. Manipulasi query database untuk mengakses data tidak sah
- c. Pemalsuan identitas pengguna menggunakan token JWT yang dicuri
- d. Remote Code Execution yang memberi penyerang kendali penuh atas server ✔

Your answer is correct.

The correct answer is: Remote Code Execution yang memberi penyerang kendali penuh atas server

Question **4**

Correct

Mark 1.00 out of 1.00

Dalam skenario CSRF, mengapa request berbahaya dari penyerang dapat diterima oleh server target sebagai request yang sah?

- a. Karena browser menonaktifkan validasi origin secara default
- b. Karena penyerang mengetahui password korban secara langsung
- c. Karena browser otomatis menambahkan session cookie korban pada request ke situs target ✔
- d. Karena server selalu menolak request POST dari pengguna anonim

Your answer is correct.

The correct answer is: Karena browser otomatis menambahkan session cookie korban pada request ke situs target

Question **5**

Correct

Mark 1.00 out of 1.00

Fungsi `htmlspecialchars()` pada PHP digunakan sebagai mitigasi XSS karena:

- a. Mengenkripsi nilai input pengguna sebelum disimpan ke database
- b. Mengubah karakter HTML khusus seperti <, >, &, dan " menjadi HTML entities yang aman ✔
- c. Menghasilkan token acak untuk diverifikasi saat form dikirimkan
- d. Memvalidasi format email dan URL yang dimasukkan oleh pengguna

Your answer is correct.

The correct answer is: Mengubah karakter HTML khusus seperti <, >, &, dan " menjadi HTML entities yang aman

Question **6**

Correct

Mark 1.00 out of 1.00

Session fixation adalah serangan di mana penyerang:

- a. Mencuri session ID yang sudah aktif menggunakan teknik XSS
- b. Menetapkan session ID tertentu pada browser korban sebelum login, lalu menggunakannya setelah korban berhasil terautentikasi ✔
- c. Menebak session ID korban secara sistematis menggunakan brute force
- d. Memperpanjang masa berlaku session korban secara tidak sah untuk akses berkelanjutan

Your answer is correct.

The correct answer is: Menetapkan session ID tertentu pada browser korban sebelum login, lalu menggunakannya setelah korban berhasil terautentikasi

Question **7**

Correct

Mark 1.00 out of 1.00

XPath Injection menarget aplikasi yang menggunakan XPath sebagai bahasa query untuk:

- a. Mengelola session pengguna yang tersimpan di sisi server
- b. Mengeksekusi query pada database relasional seperti MySQL atau PostgreSQL
- c. Mengambil dan memanipulasi data dari dokumen XML ✔
- d. Mengautentikasi pengguna menggunakan protokol direktori LDAP

Your answer is correct.

The correct answer is: Mengambil dan memanipulasi data dari dokumen XML

Question **8**

Correct

Mark 1.00 out of 1.00

Pemeriksaan `Referrer` header dapat membantu mitigasi CSRF karena:

- a. Browser akan otomatis memblokir semua request lintas domain
- b. Server dapat memeriksa apakah request berasal dari domain yang sama ✔
- c. Header tersebut menggantikan fungsi session cookie
- d. Header tersebut mengenkripsi body request

Your answer is correct.

The correct answer is: Server dapat memeriksa apakah request berasal dari domain yang sama

Question **9**

Correct

Mark 1.00 out of 1.00

Mekanisme perlindungan yang paling umum digunakan untuk mencegah CSRF pada form dan request adalah:

- a. Menonaktifkan cookie session sepenuhnya
- b. Anti-CSRF token unik untuk setiap sesi atau request ✔
- c. CAPTCHA pada semua halaman
- d. Menyembunyikan URL endpoint sensitif

Your answer is correct.

The correct answer is: Anti-CSRF token unik untuk setiap sesi atau request

Question **10**

Correct

Mark 1.00 out of 1.00

LDAP Injection menarget aplikasi yang menggunakan protokol LDAP untuk autentikasi. Dampak utama yang dapat ditimbulkan meliputi:

- a. Bypass autentikasi dan eskalasi privilege pada sistem enterprise ✔
- b. Pemalsuan request HTTP menggunakan session cookie korban
- c. Penghapusan seluruh data dari database relasional secara langsung
- d. Eksekusi JavaScript berbahaya di browser pengguna lain

Your answer is correct.

The correct answer is: Bypass autentikasi dan eskalasi privilege pada sistem enterprise

Question **11**

Correct

Mark 1.00 out of 1.00

Serangan credential stuffing memanfaatkan kondisi di mana:

- a. Penyerang mencuri session cookie melalui XSS untuk mengambil alih akun
- b. Penyerang menebak password populer satu per satu secara otomatis menggunakan tools
- c. Pengguna menggunakan kembali pasangan email-password yang sama di berbagai layanan, sehingga data bocor dari satu layanan dapat digunakan di layanan lain ✔
- d. Penyerang mengeksploitasi kelemahan algoritma enkripsi yang digunakan untuk menyimpan password

Your answer is correct.

The correct answer is: Pengguna menggunakan kembali pasangan email-password yang sama di berbagai layanan, sehingga data bocor dari satu layanan dapat digunakan di layanan lain

Question **12**

Correct

Mark 1.00 out of 1.00

`Header X-Frame-Options: DENY` pada respons HTTP berfungsi untuk mencegah serangan:

- a. CSRF dengan memblokir pengiriman form lintas domain
- b. SQL Injection melalui form yang disembunyikan di dalam iframe
- c. XSS dengan membatasi skrip yang dapat dieksekusi dari sumber eksternal
- d. Clickjacking dengan melarang halaman web dimuat di dalam elemen `<frame>` atau `<iframe>` ✔

Your answer is correct.

The correct answer is: Clickjacking dengan melarang halaman web dimuat di dalam elemen `<frame>` atau `<iframe>`

Question **13**

Correct

Mark 1.00 out of 1.00

Anti-CSRF token melindungi aplikasi dari serangan CSRF dengan cara:

- a. Memverifikasi bahwa seluruh request menggunakan metode HTTP GET dan bukan POST
- b. Membatasi jumlah request yang dapat dikirimkan dari satu alamat IP dalam periode tertentu
- c. Menyisipkan token acak unik per session ke dalam setiap form, di mana server menolak request yang tidak menyertakan token yang valid ✔
- d. Mengenkripsi seluruh body request HTTP menggunakan kunci yang hanya diketahui server

Your answer is correct.

The correct answer is: Menyisipkan token acak unik per session ke dalam setiap form, di mana server menolak request yang tidak menyertakan token yang valid

Question **14**

Correct

Mark 1.00 out of 1.00

Payload SQL Injection

```
' OR '1'='1
```

yang dimasukkan ke field email pada form login di aplikasi Juice Shop bertujuan untuk:

- a. Mengekstrak hash password seluruh pengguna melalui error message
- b. Membuat kondisi WHERE selalu bernilai TRUE sehingga autentikasi terlewati ✔
- c. Menghapus semua record pengguna dari tabel database
- d. Mengubah password admin menjadi nilai yang dipilih penyerang

Your answer is correct.

The correct answer is: Membuat kondisi WHERE selalu bernilai TRUE sehingga autentikasi terlewati

Question **15**

Correct

Mark 1.00 out of 1.00

Web application vulnerabilities adalah kelemahan atau celah keamanan pada aplikasi web yang dapat dieksploitasi penyerang. Tiga aspek keamanan informasi yang dapat terdampak adalah:

- a. Confidentiality, Identity, Authentication
- b. Confidentiality, Integrity, Availability ✔
- c. Confidence, Identity, Authenticity
- d. Confidence, Integrated, Available

Your answer is correct.

The correct answer is: Confidentiality, Integrity, Availability

Question **16**

Correct

Mark 1.00 out of 1.00

Multi-Factor Authentication (MFA) efektif melindungi dari serangan credential stuffing karena:

- a. MFA secara otomatis mendeteksi dan memblokir alamat IP yang mencurigakan
- b. Meskipun kredensial pengguna bocor, penyerang tetap membutuhkan faktor verifikasi tambahan yang tidak mereka miliki ✔
- c. MFA membuat password menjadi lebih panjang dan kompleks secara otomatis
- d. MFA mengenkripsi password di sisi client sebelum dikirimkan ke server

Your answer is correct.

The correct answer is: Meskipun kredensial pengguna bocor, penyerang tetap membutuhkan faktor verifikasi tambahan yang tidak mereka miliki

Question **17**

Correct

Mark 1.00 out of 1.00

Prinsip least privilege dalam konteks mitigasi SQL Injection berarti:

- a. Akun pengguna biasa hanya memiliki hak akses minimum sesuai kebutuhan, bukan hak DROP atau ALTER ✔
- b. Developer hanya menulis query database sesederhana mungkin
- c. Pengguna aplikasi hanya boleh mengakses halaman yang diperlukan
- d. Aplikasi hanya menyimpan data pengguna yang benar-benar dibutuhkan

Your answer is correct.

The correct answer is: Akun pengguna biasa hanya memiliki hak akses minimum sesuai kebutuhan, bukan hak DROP atau ALTER

Question **18**

Correct

Mark 1.00 out of 1.00

HTTP Strict Transport Security (HSTS) melindungi aplikasi web dari:

- a. Protocol downgrade attack dan man-in-the-middle attack dengan memaksa penggunaan HTTPS ✔
- b. CSRF dengan memvalidasi Origin header pada setiap request yang masuk
- c. SQL Injection dengan memvalidasi query secara otomatis di transport layer
- d. XSS dengan membatasi sumber skrip yang diperbolehkan untuk dieksekusi

Your answer is correct.

The correct answer is: Protocol downgrade attack dan man-in-the-middle attack dengan memaksa penggunaan HTTPS

Question **19**

Correct

Mark 1.00 out of 1.00

Header HTTP Content-Security-Policy (CSP) diimplementasikan untuk tujuan utama:

- a. Memblokir seluruh permintaan HTTP yang berasal dari domain yang berbeda
- b. Mendefinisikan daftar sumber tepercaya dari mana browser diizinkan memuat konten seperti skrip dan stylesheet ✔
- c. Mengenkripsi semua cookie session agar tidak dapat dibaca pihak ketiga
- d. Memaksa seluruh koneksi menggunakan protokol HTTPS secara otomatis

Your answer is correct.

The correct answer is: Mendefinisikan daftar sumber tepercaya dari mana browser diizinkan memuat konten seperti skrip dan stylesheet

Question **20**

Correct

Mark 1.00 out of 1.00

Cross-Site Scripting (XSS) terjadi karena aplikasi web:

- a. Tidak menerapkan anti-CSRF token pada setiap form yang memproses data sensitif
- b. Menampilkan input pengguna di halaman tanpa melakukan output encoding atau escaping yang memadai ✔
- c. Menggunakan session ID yang dapat diprediksi sehingga mudah ditebak penyerang
- d. Tidak menggunakan enkripsi HTTPS pada seluruh endpoint yang sensitif

Your answer is correct.

The correct answer is: Menampilkan input pengguna di halaman tanpa melakukan output encoding atau escaping yang memadai

◄ Hands-on OWASP Juice Shop

Jump to...

Database Security ►